CTF Layer 2 Security

Laboratorio de Ataques y Defensas en Capa 2

Julián León James Soto Mauricio Mantilla

Universidad San Francisco de Quito
Ingeniería en Ciencias de la Computación
Redes de Computadoras

Marzo 2026

Contenido

1. Introducción
2. Objetivos
3. Arquitectura
4. Red Team
5. Blue Team
6. Suricata NIDS
7. Wazuh SIEM
8. Demo y Resultados
9. Evidencia
10. Contramedidas
11. Conclusiones

Introducción y Motivación

El problema de la Capa 2

La mayoría de mecanismos de seguridad operan en capas superiores (L3+), dejando la Capa 2 desprotegida.

- ARP **no tiene autenticación**: cualquier host puede enviar respuestas falsas
- Los ataques L2 son **invisibles** para firewalls e IDS tradicionales
- Permiten **Man-in-the-Middle**, interceptación de tráfico y DoS
- Redes empresariales y campus universitarios son especialmente vulnerables

Realidad

Un atacante en la misma red local puede comprometer toda la comunicación sin que las capas superiores lo detecten.

Objetivos del Proyecto

Objetivo General

Diseñar e implementar un laboratorio CTF que simule ataques y defensas en Capa 2 usando tecnologías reales de ciberseguridad.

Objetivos Específicos:

1. Implementar ataques **ARP Spoofing** y **MAC Flooding** con Scapy
2. Desarrollar herramientas de **detección** (Blue Team) en Python
3. Integrar **Suricata** como NIDS con reglas personalizadas para L2
4. Desplegar **Wazuh** como SIEM para correlación de eventos
5. Orquestar todo en **Docker** con **CTFd** como plataforma de retos

Arquitectura del Laboratorio

Infraestructura:

- **13 contenedores** Docker
- Red bridge: `172.20.0.0/24`
- Orquestación con Docker Compose

Contenedores clave:

- `gateway` — Router/gateway
- `victim1-3` — Hosts víctima
- `redteam` — Atacante (Scapy)
- `blueteam` — Defensor
- `suricata` — NIDS
- `ctfd` — Plataforma CTF

Stack Wazuh (4 contenedores):

- `wazuh.manager`
- `wazuh.indexer`
- `wazuh.dashboard`
- `wazuh.agent` (en blueteam)

Tecnologías

- Python 3 + Scapy
- Suricata 7.x
- Wazuh 4.x (SIEM/XDR)
- CTFd 3.x

Red Team — ARP Spoofing

¿Cómo funciona?

- ARP no valida respuestas → se puede falsificar
- El atacante envía **ARP Reply** falsos a la víctima
- La víctima actualiza su tabla ARP con la MAC del atacante
- Resultado: tráfico redirigido (**MitM**)

Modo broadcast:

- Envío a `ff:ff:ff:ff:ff:ff`
- Envenena **todos** los hosts simultáneamente

Código Scapy (simplificado):

```
pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
    / ARP(op=2,
      psrc=gateway_ip,
      hwsrc=attacker_mac,
      pdst=victim_ip)
sendp(pkt, iface="eth0")
```

Impacto

Interceptación completa del tráfico entre víctima y gateway.

Red Team — MAC Flooding

¿Cómo funciona?

- Los switches tienen una **tabla CAM** de tamaño finito
- Se inundan con miles de tramas con **MACs aleatorias**
- Al llenarse la tabla, el switch entra en modo **fail-open**
- El switch actúa como **hub**: envía todo a todos los puertos

Consecuencia:

- El atacante puede capturar tráfico de toda la red

Código Scapy:

```
mac = RandMAC()
pkt = Ether(src=mac, dst=mac)
    / ARP(op=1,
      hwsrc=mac,
      psrc=RandIP())
sendp(pkt, iface="eth0",
      loop=1, inter=0.001)
```

Velocidad

Miles de MACs por segundo para saturar la tabla CAM.

Blue Team — Detección

ARP Monitor (Híbrido Activo + Pasivo)

- **Pasivo:** Captura y analiza paquetes ARP en tiempo real
- **Activo:** Envía ARP Requests periódicos para verificar consistencia
- Detecta cambios sospechosos en mapeos IP $\leftrightarrow$ MAC
- Genera alertas cuando detecta **ARP Spoofing**

MAC Anomaly Detector

- Monitorea nuevas direcciones MAC en la red
- Detecta **ráfagas atípicas** de MACs nuevas (umbral configurable)
- Identifica patrones de **MAC Flooding**
- Registra eventos para correlación en Wazuh

Blue Team — Restauración ARP

Respuesta Activa

Una vez detectado el ataque, el Blue Team puede **restaurar** las tablas ARP de las víctimas.

Proceso de restauración:

1. Detectar el ARP Spoofing (alerta del monitor)
2. Obtener los mapeos **legítimos** IP $\leftrightarrow$ MAC
3. Enviar **ARP Reply correctos** a las víctimas afectadas
4. Verificar que las tablas ARP se restauraron

Resultado

Las víctimas recuperan los mapeos ARP legítimos y el tráfico vuelve a fluir por la ruta correcta.

Suricata — Sistema de Detección de Intrusos

Desafío

Suricata no soporta `arp` como protocolo directamente en reglas. Se usa **pkthdr** para inspeccionar tramas a nivel de enlace.

7 reglas personalizadas para detección L2:

- Detección de **ARP Reply** sospechosos (alto volumen)
- Detección de **ARP broadcast** anómalos
- Identificación de patrones de **MAC Flooding**
- Alertas por cambios rápidos en mapeos ARP

Ejemplo de regla:

```
alert pkthdr any any -> any any (msg:"ARP
  Spoofing detectado"; content:"|00 06|";
  offset:12; depth:2; sid:1000001; rev:1;)
```

Wazuh — SIEM y Correlación de Eventos

Integración:

- Logs compartidos vía **volúmenes Docker**
- Suricata → `eve.json` → Wazuh
- Blue Team scripts → logs → Wazuh

Reglas personalizadas:

- IDs: 100010 – 100021
- Niveles de severidad 5–12
- Correlación de múltiples fuentes

Capacidades:

- Dashboard centralizado
- Threat Hunting interactivo
- Visualización de alertas L2
- Historial de eventos

Ventaja

Visibilidad completa de ataques L2 desde una **única consola**, correlacionando datos de Suricata y scripts Blue Team.

Demo — Resultados del CTF

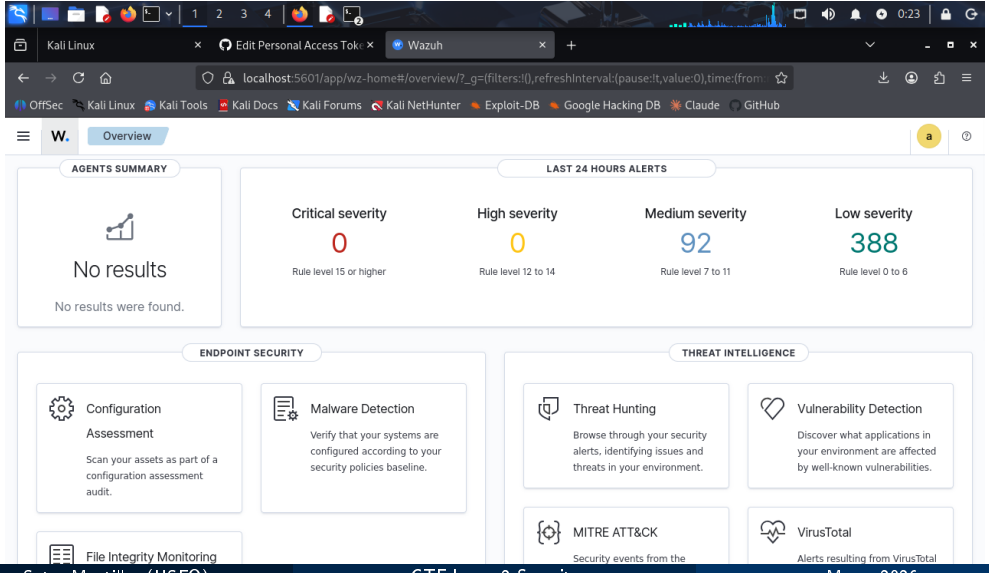
Retos completados: 3/3 flags capturados

Reto	Flag	Puntos
ARP Spoofing	`FLAG{arp_spoof_detected}`	100
MAC Flooding	`FLAG{mac_flood_detected}`	100
Restauración	`FLAG{arp_restored}`	150

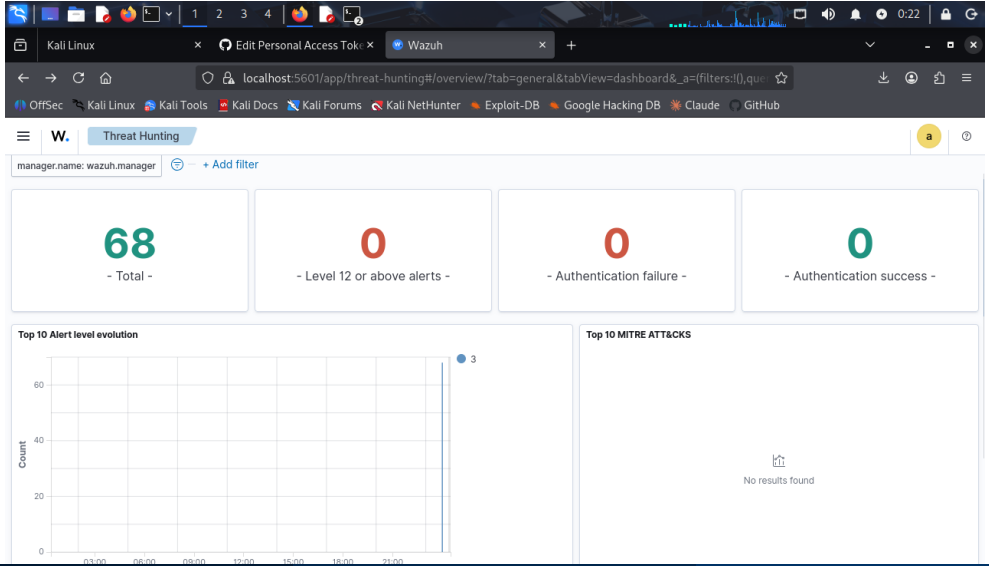
Flujo del CTF:

1. Red Team ejecuta el ataque
2. Blue Team detecta y genera evidencia
3. Se valida la flag en **CTFd**
4. SIEM registra todo el proceso

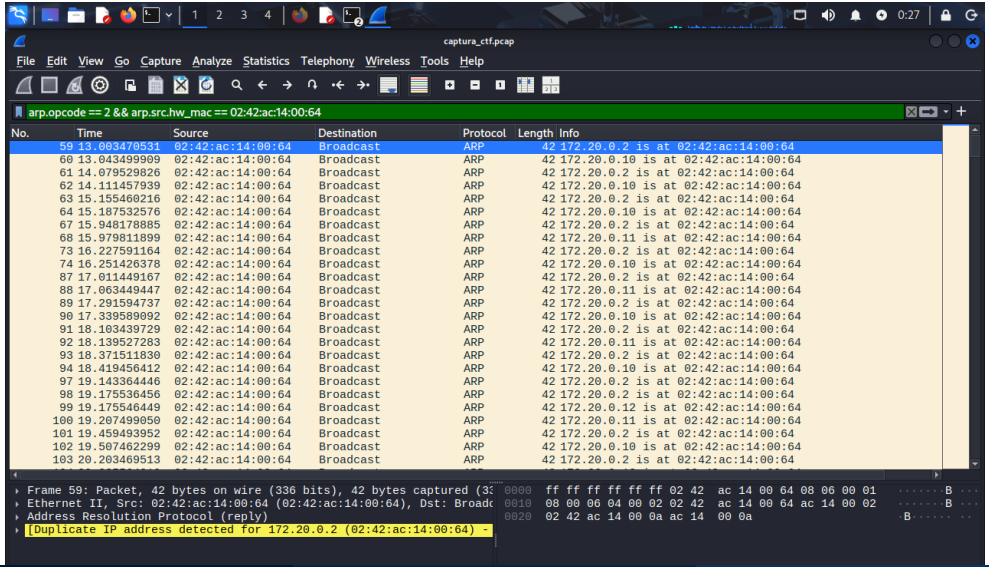
Evidencia — Wazuh Dashboard Overview



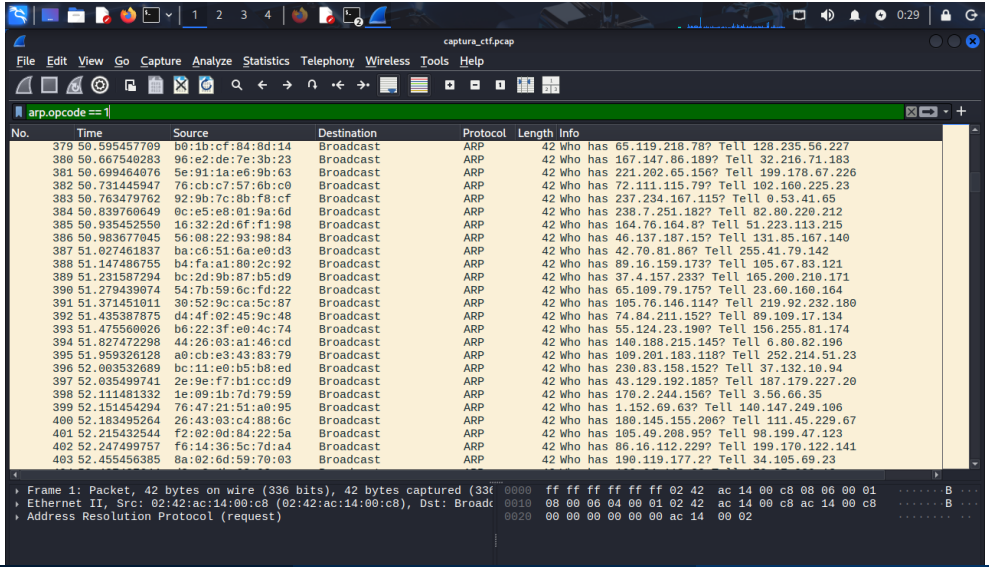
Evidencia — Wazuh Threat Hunting



Evidencia — Captura ARP Spoofing (Wireshark)



Evidencia — Captura MAC Flooding (Wireshark)



Contramedidas Recomendadas

Nivel de Switch:

- **DAI** (Dynamic ARP Inspection)
  - Valida paquetes ARP contra tabla DHCP
- **Port Security**
  - Limita MACs por puerto
  - Previene MAC Flooding
- **DHCP Snooping**
  - Filtra mensajes DHCP no autorizados

Nivel de Red/Aplicación:

- **802.1X**
  - Autenticación por puerto
  - NAC (Network Access Control)
- **TLS/SSL**
  - Cifrado extremo a extremo
  - Mitiga impacto de MitM
- **Monitoreo continuo**
  - SIEM + NIDS (Wazuh + Suricata)
  - Alertas en tiempo real

Conclusiones y Lecciones Aprendidas

Conclusiones:

- La Capa 2 es un **vector de ataque real** frecuentemente ignorado
- ARP Spoofing y MAC Flooding son **fáciles de ejecutar** pero difíciles de detectar sin herramientas especializadas
- La combinación **Suricata + Wazuh** proporciona visibilidad efectiva en L2
- Docker permite crear **laboratorios realistas** de forma reproducible

Lecciones aprendidas:

- Suricata requiere técnicas especiales (`pkthdr`) para L2
- La detección híbrida (activa + pasiva) es más robusta
- CTFd gamifica el aprendizaje de seguridad de forma efectiva
- La automatización con Docker Compose simplifica despliegues complejos

¿Preguntas?

Gracias por su atención

Julián León · James Soto · Mauricio Mantilla

Redes de Computadoras -- USFQ

Marzo 2026